

Reporte de Auditoría de Seguridad DRF

Proyecto: ./vulnerable_api | Generado: 2026-07-01 15:55:32

Total	HIGH	MEDIUM	LOW	INFO
25	20	4	1	0

Hallazgos (25)

HIGH	Posible BOLA en ruta 'users/'			API1
Regla	API1-BOLA-URL			
Archivo	/Users/nohelestradap/Documents/tesis_proyecto/vulnerable_api/core/urls.py:12			
Descripción	La ruta 'users/' acepta un identificador numérico. Si la vista correspondiente no verifica que el objeto solicitado pertenece al usuario autenticado, cualquier usuario puede acceder a datos ajenos cambiando el parámetro (BOLA/IDOR).			
Evidencia	path('users/', views.UserDetailView.as_view(), name='user-detail'),			
HIGH	Posible BOLA en ruta 'products/'			API1
Regla	API1-BOLA-URL			
Archivo	/Users/nohelestradap/Documents/tesis_proyecto/vulnerable_api/core/urls.py:16			
Descripción	La ruta 'products/' acepta un identificador numérico. Si la vista correspondiente no verifica que el objeto solicitado pertenece al usuario autenticado, cualquier usuario puede acceder a datos ajenos cambiando el parámetro (BOLA/IDOR).			
Evidencia	path('products/', views.ProductDetailView.as_view(), name='product-detail'),			
HIGH	Posible BOLA en ruta 'orders/'			API1
Regla	API1-BOLA-URL			
Archivo	/Users/nohelestradap/Documents/tesis_proyecto/vulnerable_api/core/urls.py:20			
Descripción	La ruta 'orders/' acepta un identificador numérico. Si la vista correspondiente no verifica que el objeto solicitado pertenece al usuario autenticado, cualquier usuario puede acceder a datos ajenos cambiando el parámetro (BOLA/IDOR).			
Evidencia	path('orders/', views.OrderDetailView.as_view(), name='order-detail'),			

HIGH	Posible BOLA en ruta 'admin-panel/'	API1
Regla	API1-BOLA-URL	
Archivo	/Users/nohelestradap/Documents/tesis_proyecto/vulnerable_api/core/urls.py:24	
Descripción	La ruta 'admin-panel/' acepta un identificador numérico. Si la vista correspondiente no verifica que el objeto solicitado pertenece al usuario autenticado, cualquier usuario puede acceder a datos ajenos cambiando el parámetro (BOLA/IDOR).	
Evidencia	<pre>path('admin-panel/', views.AdminPanelView.as_view(), name='admin-panel-delete'),</pre>	
HIGH	BOLA: acceso a objeto de otro usuario	API1
Regla	API1-BOLA	
Endpoint	GET /api/orders/1/	
Descripción	El usuario 'bob' puede acceder a /api/orders/1/ que pertenece a 'alice'. El servidor no verifica que el objeto solicitado pertenezca al usuario autenticado.	
Evidencia	<pre>HTTP 200 con token de bob. Body: {"id":1,"quantity":1,"created_at":"2026-04-06T22:39:45.739879Z","owner":1,"product":1}</pre>	
HIGH	Vista 'UserListView' sin permission_classes	API2
Regla	API2-NO-PERMISSION	
Archivo	/Users/nohelestradap/Documents/tesis_proyecto/vulnerable_api/core/views.py:10	
Descripción	La vista 'UserListView' no define permission_classes. Si DEFAULT_PERMISSION_CLASSES no está configurado en settings, cualquier usuario anónimo puede acceder al endpoint.	
Evidencia	<pre>class UserListView(generics.ListCreateAPIView):</pre>	
HIGH	Vista 'UserDetailView' sin permission_classes	API2
Regla	API2-NO-PERMISSION	
Archivo	/Users/nohelestradap/Documents/tesis_proyecto/vulnerable_api/core/views.py:16	
Descripción	La vista 'UserDetailView' no define permission_classes. Si DEFAULT_PERMISSION_CLASSES no está configurado en settings, cualquier usuario anónimo puede acceder al endpoint.	
Evidencia	<pre>class UserDetailView(generics.RetrieveUpdateDestroyAPIView):</pre>	
HIGH	Vista 'ProductListView' sin permission_classes	API2
Regla	API2-NO-PERMISSION	
Archivo	/Users/nohelestradap/Documents/tesis_proyecto/vulnerable_api/core/views.py:21	
Descripción	La vista 'ProductListView' no define permission_classes. Si DEFAULT_PERMISSION_CLASSES no está configurado en settings, cualquier usuario anónimo puede acceder al endpoint.	
Evidencia	<pre>class ProductListView(generics.ListCreateAPIView):</pre>	

HIGH	Vista 'ProductDetailView' sin permission_classes		API2
Regla	API2-NO-PERMISSION		
Archivo	/Users/nohelestradap/Documents/tesis_proyecto/vulnerable_api/core/views.py:26		
Descripción	La vista 'ProductDetailView' no define permission_classes. Si DEFAULT_PERMISSION_CLASSES no está configurado en settings, cualquier usuario anónimo puede acceder al endpoint.		
Evidencia	<pre>class ProductDetailView(generics.RetrieveUpdateDestroyAPIView):</pre>		
HIGH	Vista 'OrderDetailView' sin permission_classes		API2
Regla	API2-NO-PERMISSION		
Archivo	/Users/nohelestradap/Documents/tesis_proyecto/vulnerable_api/core/views.py:33		
Descripción	La vista 'OrderDetailView' no define permission_classes. Si DEFAULT_PERMISSION_CLASSES no está configurado en settings, cualquier usuario anónimo puede acceder al endpoint.		
Evidencia	<pre>class OrderDetailView(generics.RetrieveUpdateDestroyAPIView):</pre>		
HIGH	Vista 'OrderListView' sin permission_classes		API2
Regla	API2-NO-PERMISSION		
Archivo	/Users/nohelestradap/Documents/tesis_proyecto/vulnerable_api/core/views.py:40		
Descripción	La vista 'OrderListView' no define permission_classes. Si DEFAULT_PERMISSION_CLASSES no está configurado en settings, cualquier usuario anónimo puede acceder al endpoint.		
Evidencia	<pre>class OrderListView(generics.ListCreateAPIView):</pre>		
HIGH	Vista 'AdminPanelView' sin permission_classes		API2
Regla	API2-NO-PERMISSION		
Archivo	/Users/nohelestradap/Documents/tesis_proyecto/vulnerable_api/core/views.py:47		
Descripción	La vista 'AdminPanelView' no define permission_classes. Si DEFAULT_PERMISSION_CLASSES no está configurado en settings, cualquier usuario anónimo puede acceder al endpoint.		
Evidencia	<pre>class AdminPanelView(APIView):</pre>		
HIGH	Acceso sin autenticación: GET /api/users/		API2
Regla	API2-UNAUTH		
Endpoint	GET /api/users/		
Descripción	El endpoint responde 200 sin requerir token de autenticación. Cualquier cliente puede acceder a datos sensibles sin identificarse.		
Evidencia	<pre>HTTP 200 (esperado 401). Body (primeros 200 chars): [{"id":1,"username":"alice", "email":"alice@test.com","password":"pbkdf2_sha256\$600000\$dqQSBrrqZ32sgUzH2dxfn Kr\$Iqb3gdUf/XsBeJV3K0Pubz/0FMGT7UYi3AqYXV5</pre>		

HIGH	Acceso sin autenticación: GET /api/orders/		API2
Regla	API2-UNAUTH		
Endpoint	GET /api/orders/		
Descripción	El endpoint responde 200 sin requerir token de autenticación. Cualquier cliente puede acceder a datos sensibles sin identificarse.		
Evidencia	HTTP 200 (esperado 401). Body (primeros 200 chars): [{"id":1,"quantity":1,"created_at":"2026-04-06T22:39:45.739879Z","owner":1,"product":1},{ "id":2,"quantity":2,"created_at":"2026-04-06T22:39:45.74057		

HIGH	Acceso sin autenticación: GET /api/admin-panel/		API2
Regla	API2-UNAUTH		
Endpoint	GET /api/admin-panel/		
Descripción	El endpoint responde 200 sin requerir token de autenticación. Cualquier cliente puede acceder a datos sensibles sin identificarse.		
Evidencia	HTTP 200 (esperado 401). Body (primeros 200 chars): {"admin_data":[{"id":1,"username":"alice","email":"alice@test.com","is_admin":false,"password":"pbkdf2_sha256\$600000\$ddqQSBrqZ32sgUzH2dxfnKr\$Iqb3gdUf		

HIGH	Campo sensible 'is_admin' expuesto sin read_only en 'UserSerializer'		API3
Regla	API3-SENSITIVE-FIELD		
Archivo	/Users/nohelestradap/Documents/tesis_proyecto/vulnerable_api/core/serializers.py:5		
Descripción	El serializer 'UserSerializer' incluye 'is_admin' en Meta.fields sin marcarlo como read_only. Un cliente puede modificar este campo directamente en una petición POST/PUT/PATCH (mass assignment).		
Evidencia	class UserSerializer(serializers.ModelSerializer):		

HIGH	Campo sensible 'is_staff' expuesto sin read_only en 'UserSerializer'		API3
Regla	API3-SENSITIVE-FIELD		
Archivo	/Users/nohelestradap/Documents/tesis_proyecto/vulnerable_api/core/serializers.py:5		
Descripción	El serializer 'UserSerializer' incluye 'is_staff' en Meta.fields sin marcarlo como read_only. Un cliente puede modificar este campo directamente en una petición POST/PUT/PATCH (mass assignment).		
Evidencia	class UserSerializer(serializers.ModelSerializer):		

HIGH	Campo sensible 'password' expuesto sin read_only en 'UserSerializer'		API3
Regla	API3-SENSITIVE-FIELD		
Archivo	/Users/nohelestradap/Documents/tesis_proyecto/vulnerable_api/core/serializers.py:5		
Descripción	El serializer 'UserSerializer' incluye 'password' en Meta.fields sin marcarlo como read_only. Un cliente puede modificar este campo directamente en una petición POST/PUT/PATCH (mass assignment).		
Evidencia	class UserSerializer(serializers.ModelSerializer):		

HIGH	Función admin accesible sin rol: GET /api/admin-panel/		API5
Regla	API5-FUNC-AUTHZ		
Endpoint	GET /api/admin-panel/		
Descripción	El endpoint de administración responde 200 sin requerir autenticación ni verificar que el usuario tenga rol de administrador. Cualquier cliente puede invocar funciones privilegiadas.		
Evidencia	HTTP 200 sin token. Body (primeros 200 chars): {"admin_data":[{"id":1,"username":"alice","email":"alice@test.com","is_admin":false,"password":"pbkdf2_sha256\$6000000\$dqQ\$BrqZ32sgUzH2dxfnKr\$Iqb3gdUf/XsBe		
HIGH	DEBUG=True habilitado en settings		API8
Regla	API8-DEBUG-ENABLED		
Archivo	/Users/nohelestradap/Documents/tesis_proyecto/vulnerable_api/config/settings.py:8		
Descripción	DEBUG=True expone stack traces completos con rutas del sistema, variables de entorno y configuración interna ante cualquier error. Debe ser False en cualquier entorno no local.		
Evidencia	DEBUG = True		
MEDIUM	Serializer 'ProductSerializer' usa fields='__all__'		API3
Regla	API3-FIELDS-ALL		
Archivo	/Users/nohelestradap/Documents/tesis_proyecto/vulnerable_api/core/serializers.py:12		
Descripción	'ProductSerializer' expone todos los campos del modelo con fields='__all__'. Esto puede incluir campos sensibles no intencionados. Enumera explícitamente los campos permitidos.		
Evidencia	class ProductSerializer(serializers.ModelSerializer):		
MEDIUM	Serializer 'OrderSerializer' usa fields='__all__'		API3
Regla	API3-FIELDS-ALL		
Archivo	/Users/nohelestradap/Documents/tesis_proyecto/vulnerable_api/core/serializers.py:18		
Descripción	'OrderSerializer' expone todos los campos del modelo con fields='__all__'. Esto puede incluir campos sensibles no intencionados. Enumera explícitamente los campos permitidos.		
Evidencia	class OrderSerializer(serializers.ModelSerializer):		
MEDIUM	REST_FRAMEWORK sin DEFAULT_THROTTLE_CLASSES		API4
Regla	API4-NO-THROTTLING		
Archivo	/Users/nohelestradap/Documents/tesis_proyecto/vulnerable_api/config/settings.py:62		
Descripción	El diccionario REST_FRAMEWORK no define DEFAULT_THROTTLE_CLASSES ni DEFAULT_THROTTLE_RATES. Sin rate limiting global, cualquier cliente puede hacer requests ilimitados (fuerza bruta, scraping, DoS).		
Evidencia	REST_FRAMEWORK = {		

MEDIUM	Sin throttling: endpoint no limita requests		API4
Regla	API4-NO-THROTTLE		
Endpoint	GET /api/products/		
Descripción	Se enviaron 20 requests consecutivos a /api/products/ sin recibir respuesta 429 (Too Many Requests). La API no tiene rate limiting configurado.		
Evidencia	20 requests respondidos sin HTTP 429.		

LOW	Configuración SIMPLE_JWT ausente en settings		API2
Regla	API2-NO-JWT-CONFIG		
Archivo	/Users/nohelestradap/Documents/tesis_proyecto/vulnerable_api/config/settings.py:1		
Descripción	No se encontró la variable SIMPLE_JWT en settings. Sin configuración explícita, los tokens usan los tiempos de expiración por defecto de django-restframework-simplejwt. Se recomienda definir ACCESS_TOKEN_LIFETIME y REFRESH_TOKEN_LIFETIME según la política de seguridad.		
Evidencia	# SIMPLE_JWT = { ... } <-- ausente		

Cobertura OWASP API Security Top 10

API1	API2	API3	API4	API5	API8
------	------	------	------	------	------

Métricas de la auditoría

Hallazgos estáticos (AST)	19
Hallazgos dinámicos (HTTP)	6
Recomendaciones LLM generadas	0
Categorías OWASP detectadas	6 / 10